ROSI e ponto de equilíbrio

Como comparar o custo de uma proteção adicional com a redução estimada de perdas, sob premissas explícitas.

Material genérico. Não usa respostas, cálculos ou dados de qualquer pessoa ou empresa. Não é diagnóstico, auditoria, certificação, previsão ou benchmark, e não é personalizado a partir das suas respostas.

O que o tema significa

O retorno sobre investimento em segurança (ROSI) compara o benefício esperado de uma medida de proteção com o custo dela no mesmo período. O benefício é a redução estimada de perdas financeiras, e não um lucro realizado. O resultado só é tão confiável quanto as estimativas de perda, frequência, eficácia e custo que o alimentam.

A estimativa de perdas exige identificar e analisar o risco de forma documentada. O NIST IR 8286A Rev. 1 trata justamente da identificação e da estimativa de risco de segurança cibernética para a gestão de risco corporativo, e serve de base para estruturar essas premissas.

Método da ferramenta

ADAPTAÇÃO ROOT TRUST Simplificação com horizonte de 12 meses e hipóteses visíveis. Não é o modelo oficial de nenhuma instituição citada.

L = prejuízo por incidente × frequência anual esperada de incidentes com prejuízo (perda de referência, mantendo os controles atuais).

f = (12 – d) / 12, para prazo d em meses até a proteção estar efetiva (f = 0 quando d ≥ 12).

B = L × e × f, em que e é a redução estimada das perdas durante a operação efetiva (de 0% a 100%).

ROSI = (B – C) / C × 100, para custo adicional C > 0 no período de 12 meses.

Redução de equilíbrio = C / (L × f) × 100, quando L × f > 0. Equilíbrio é ROSI de 0%.

Custo e perda precisam estar na mesma moeda e no mesmo horizonte. Valores desconhecidos não devem ser tratados como zero. Quando um dado essencial falta, o resultado correspondente não deve ser calculado.

Limites

- O resultado depende inteiramente das premissas. Não representa economia realizada nem a postura de segurança da organização.
- Um percentual de ROSI positivo não recomenda contratar a proteção; um negativo não recomenda dispensá-la.
- Um equilíbrio acima de 100% indica que a redução necessária excede as perdas incluídas no cenário, e não deve ser truncado.
- O modelo analisa um cenário por vez e não soma riscos diferentes. Benefícios de outras proteções já existentes não são atribuídos à medida avaliada.
- Prazo de 12 meses ou mais significa que não há benefício dentro do horizonte.

Próximos passos

1. Definir um único cenário de incidente e listar as perdas financeiras sem sobreposição entre elas.
2. Registrar a origem de cada estimativa: histórico próprio, cotação, referência externa ou hipótese declarada.

3. Comparar a operação atual com a proteção adicional, incluindo implantação, despesas e trabalho interno do período.
4. Revisar as premissas com quem responde pela área de segurança e pela área financeira antes de decidir.
5. Repetir a análise quando surgirem dados novos, como incidentes reais ou cotações formais.

Fontes oficiais consultadas

- REFERÊNCIA OFICIAL NIST. *Identifying and Estimating Cybersecurity Risk for Enterprise Risk Management* (NIST IR 8286A Rev. 1), dez/2025. csrc.nist.gov/pubs/ir/8286/a/r1/final

Consultada em 12/10/2026. Escopo de método: F03–F18 da Root Trust, versão de 11/10/2026.

Solicitar diagnóstico

Conversa inicial gratuita de qualificação, pelo e-mail contato@roottrust.com.br. Não é auditoria, não há agenda automática e não inclui relatório personalizado.